

Scope: Gym-backend (Spring Boot API) + Gym-frontend (React/TypeScript web app)

TABLE OF CONTENTS

1. Introduction	11. HR & Payroll
2. System Overview & Architecture	12. Assets
3. User Roles & Personas	13. GymOS & BIOS (Admin Console & AI Insights)
4. Module Map (Summary)	14. Community & Member Self-Service Hub
5. Authentication & Access Control	15. Automation & Notifications
6. Member Management	16. Reports & Analytics
7. Member Connect (CRM & Engagement)	17. Data Model Overview
8. Attendance, Check-In & Facilities/Bookings	18. Non-Functional Requirements
9. Sales, Point of Sale & Inventory / Purchasing	19. Known Gaps, Risks & Incomplete Areas
10. Financials & Accounting	20. Glossary

1. INTRODUCTION

1.1 Purpose

This Functional Specification Document (FSD) describes, in plain language, what the GymBios platform currently does. It was produced by directly examining the working codebase (backend controllers/entities and frontend pages/services) rather than from a pre-existing design document, so it reflects actual current behaviour, including features that are incomplete or not yet wired up. Anywhere the implementation appears to fall short of what the UI promises, this is called out explicitly in a "gap" callout so it can be tracked as future work rather than mistaken for finished functionality.

1.2 Product Summary

GymBios is an all-in-one management system for a gym or fitness club chain. It replaces separate spreadsheets/tools for membership administration, front-desk check-in, point-of-sale retail, accounting/bookkeeping, HR & payroll,

inventory/procurement, marketing & lead follow-up, and member-facing community/social features, with one connected web application and a shared database.

| 1.3 Intended Audience

Gym owners/operators, gym staff (front desk, trainers, accountants, HR), members using the self-service portal, and the engineering team maintaining or extending the system.

| 1.4 How This Document Is Organised

Section 4 gives a one-page summary of every module. Sections 5–16 describe each module in detail: what a user can do, which screens/pages provide it, and which backend rules govern it. Section 17 summarises the underlying data model. Sections 18–19 cover quality attributes and known gaps.

2. SYSTEM OVERVIEW & ARCHITECTURE

| 2.1 High-Level Architecture

GymBios is a classic two-tier web application:

- **Frontend (Gym-frontend)** — a React 18+ TypeScript single-page application built with Vite, styled with Tailwind CSS and the Radix/shadcn UI component library, using Recharts for charts. It runs in the browser and talks to the backend exclusively over a REST API.
- **Backend (Gym-backend)** — a Java Spring Boot 3 application exposing a REST API under `/api/**`, backed by a PostgreSQL database ("GYMBIOS"). Business data is organised into roughly 77 entities managed by 57 services and exposed through 50 REST controllers.
- **Mobile companion (Gym-app)** — an Expo/React Native project exists in the repository alongside the web app, suggesting a companion mobile app is planned or in early development (not analysed in depth in this document).

2.2 Technology Stack

Layer	Technology
Frontend framework	React 18, TypeScript, Vite
UI components	Radix UI / shadcn-style component library, Tailwind CSS, lucide-react icons
Charts	Recharts
Frontend routing	React Router v6, single global route guard
Backend framework	Spring Boot 3 (Java), Spring Security, Spring Data JPA/Hibernate
Database	PostgreSQL (schema auto-updated by Hibernate, ddl-auto update)
Authentication	Stateless JWT (24-hour expiry) + a separate device-key mechanism for hardware check-in terminals
Email	Spring Mail (SMTP, host/credentials externally configured)
Mobile	Expo / React Native (companion app, separate codebase)

2.3 Design Conventions Worth Knowing

- Almost every "status" or "state" field in the system (membership status, invoice status, approval status, etc.) is stored as free text rather than a fixed set of values enforced by the database or the programming language. This gives flexibility but means the valid values for any given status are defined by convention in the service code, not guaranteed by the system.
- Every business module that produces data (leads, follow-ups, referrals, products, assets, wastage/returns, etc.) exposes its own small "stats" endpoint that feeds a KPI tile on that module's page, rather than routing through one central reporting engine.
- Both members and staff have a parallel "grant portal access" pattern — an admin can set login credentials for a member or staff record and toggle whether that person may log in, unifying how self-service accounts are provisioned.

3. USER ROLES & PERSONAS

Seven roles are defined in the system: **ADMIN**, **MANAGER**, **ACCOUNTANT**, **HR**, **STAFF**, **USER**, and **MEMBER**. A person's role(s) are issued inside their login token and read by the frontend to decide what to show them.

Role	Typical User	Primary Areas of Use
ADMIN	Gym owner / system administrator	Everything — full configuration, financials, HR, GymOS control panel
MANAGER	Branch / operations manager	Members, sales, bookings, staff oversight, most reports
ACCOUNTANT	Finance / bookkeeping staff	Ledgers, vouchers, expenses, tax compliance, financial reports
HR	Human-resources staff	Staff records, payroll, salary advances, recruitment
STAFF	Front-desk staff, trainers	Check-in, attendance, bookings, POS, class/training management
USER	Generic internal user	Baseline authenticated access
MEMBER	Gym member (customer)	Member Hub self-service: profile, bookings, community, personal stats/targets

Important Caveat on Role Enforcement

Although these roles and role-scoped API rules are defined in the backend configuration, the effective security rule currently in place opens all `/api/**` endpoints to any request regardless of role (see §5.3 and §19). Separately, the frontend does not hide or block navigation by role at the routing level — any logged-in user can browse to any screen; individual pages perform their own ad-hoc role checks to hide sensitive actions. This is documented in detail in the Known Gaps section, as it materially affects how "role-based access" should be described to stakeholders today.

4. MODULE MAP (SUMMARY)

The table below is a one-page index of every functional module covered in this document, what it's for, and its overall maturity in the current codebase.

#	Module	Purpose	Status
5	Authentication & Access Control	Login, sessions, roles, device check-in keys	Partial — see gaps
6	Member Management	Member records, plans, renewals, freeze/unfreeze, billing	Core / Complete
7	Member Connect (CRM)	Leads, follow-ups, referrals, promotions, messaging, automations	Core / Complete
8	Attendance, Check-In & Bookings	Entry/exit logging, facility & class bookings, QR/device check-in	Core / Complete
9	Sales, POS & Inventory	Retail POS, products, purchase orders, suppliers, production	Core / Complete
10	Financials & Accounting	Double-entry ledger, vouchers, bank reconciliation, tax, reports	Core / Complete
11	HR & Payroll	Staff records, attendance, payroll runs, advances, recruitment	Core / Complete
12	Assets	Asset register, maintenance, transfers	Core / Complete
13	GymOS & BIOS	System admin console; AI-generated business insights	Partial
14	Community & Member Hub	Member social feed, self-service profile, bookings, challenges	Core / Complete
15	Automation & Notifications	Trigger-based messaging (birthdays, expiry, low attendance...)	Core / Complete
16	Reports & Analytics	Cross-module reporting, dashboards, custom report builder	Core / Complete
—	Public Pricing Page	Marketing page for prospective gym-owner customers of GymBios itself	Complete
—	Settings pages (sales, payroll, asset, profile)	Module-level configuration screens	Not implemented (placeholder)

5. AUTHENTICATION & ACCESS CONTROL

5.1 Login

Users sign in from the Login screen with an email/username and password. On success, the backend issues a signed JWT (valid 24 hours) containing the user's role(s); the frontend stores the token and derived user profile for the session. A "remember me" option and inline validation with success/error toasts are provided. No self-service

"forgot password" or sign-up flow is currently exposed in the routed application, even though the underlying capability exists in the backend.

| 5.2 Session & Route Protection

Every screen in the application sits behind a single check: "is someone logged in?" If not, the user is redirected to the login page. One explicit exception exists — an Emergency Profile page (accessible via a direct link, intended for QR-code/badge scanning) is reachable without logging in, so that a member's emergency contact and medical information can be viewed quickly in a medical emergency.

| 5.3 Role Enforcement

The backend defines role-scoped rules for API areas (e.g. only ADMIN can reach admin endpoints; only HR/ADMIN can reach payroll endpoints; only ACCOUNTANT/MANAGER/ADMIN can reach billing/expenses). However, a broader "allow all" rule for the entire API is currently applied ahead of those specific rules, so in practice every API endpoint accepts requests without enforcing them, except the Community module, which explicitly requires the caller to be authenticated. See §19 for the risk this creates and the recommended remediation.

| 5.4 Device Check-In Keys

Separately from user login, the system supports provisioning "device keys" for unattended hardware such as turnstiles or check-in kiosks. A device authenticates using a special header rather than a user JWT, allowing it to record check-ins without a human logging in on that terminal.

6. MEMBER MANAGEMENT

This is the system of record for every paying gym member.

| 6.1 Member Directory & Profile

Staff can search, filter, and page through the full member list, open a member's profile (photo, contact details, plan, status), and generate a detailed membership report that can be exported or scheduled. New members are added or existing ones edited through a single multi-section intake form covering personal details, address, plan selection, payment details, a photo (with crop/zoom), and emergency-contact/medical information (allergies, blood group, medications). Pending member applications can be reviewed and approved or rejected before becoming active members.

| 6.2 Membership Plans

Administrators maintain a catalogue of membership plans (pricing, duration, included features, bundled facilities/training streams, promo codes), including duplicating an existing plan as a starting point for a new one.

| 6.3 Renewal, Freeze & Upgrade

A dedicated renewal screen shows how much of the current plan a member has used (days remaining, progress bar) and lets staff renew, upgrade, or apply a promotion, followed by payment. A separate freeze/unfreeze workflow

lets staff pause a membership for a date range with a reason, and later resume it, keeping a history of past freezes. Family-plan relationships (a "family head" member linked to dependents) are supported in the data model.

| 6.4 Billing & Dues

Staff can see every member's outstanding balance, search and reprint receipts, send a receipt or a payment reminder by email/SMS (individually or in bulk), and freeze the account of a member who is significantly overdue. Receipts can also be created directly for a one-off charge.

| 6.5 Add-ons

Members (or staff on their behalf) can purchase add-ons such as extra personal-training sessions or guest passes from a small storefront-style screen, with a record of past add-on purchases.

| 6.6 Business Rules

- Membership status (active/inactive/suspended/expired) and payment status (paid/overdue/pending) are tracked per member and drive which actions are available.
- Renewing a membership recalculates its expiry date from the selected plan.
- Freezing requires a reason and a date range and is reversible via an explicit unfreeze action.
- A member can optionally be granted their own portal login (credentials + an access toggle), independent of their membership status.

7. MEMBER CONNECT (CRM & ENGAGEMENT)

This module covers everything involved in turning a prospect into a member and keeping existing members engaged.

| 7.1 Leads

A sales-style pipeline: a list of leads with a lead score and pipeline status, conversion-rate and "hot lead" KPIs, and a detail panel per lead showing contact info, notes, full interaction history, and quick actions (log a call, convert to member).

| 7.2 Follow-Ups

A task queue of scheduled follow-up actions (e.g. "call this lead/member back") with pending/overdue/due-today counts and a success-rate KPI. Each follow-up can be completed, cancelled, or rescheduled, and overdue ones can be bulk-flagged. Each follow-up keeps a linked communication history and a snapshot of the related member's status at the time.

| 7.3 Referral Program

Tracks members referring new prospects: a referral funnel, per-member referral activity, and configurable reward rules (rather than hard-coded rewards) that determine what a referrer earns when a referral is marked successful.

| 7.4 Promotions & Campaigns

Staff can build discount promotions (percentage or fixed amount, with a validity window and usage limits), duplicate an existing promotion, and review performance analytics per campaign.

| 7.5 Messaging

A bulk-communication console for emailing/texting members, prospects, or defined groups, with reusable message templates, send history, and analytics (send rate, open rate, cost).

| 7.6 Automations

A workflow builder for automated engagement — covered in full in §15, since it is also used outside the CRM context (e.g. class reminders).

| 7.7 Post-Workout Check-In & Plans/Services Catalogue

Staff can capture post-session feedback and satisfaction ratings for members, with aggregate satisfaction/recommendation analytics. A combined, browsable catalogue presents membership plans, specialised training programs, and the group-class schedule together — including a full-screen "kiosk" display mode suitable for a reception-area screen.

8. ATTENDANCE, CHECK-IN & FACILITIES/BOOKINGS

| 8.1 Front-Desk Check-In

A kiosk-style screen lets front-desk staff look up a member or staff member by name or QR code and check them in or out, or register a walk-in day-pass sale for a non-member using a daily-rate pricing table. Check-in can also happen unattended through a paired hardware device using a device key (see §5.4).

| 8.2 Attendance Records & Reports

A gym-wide attendance dashboard shows check-in/out activity and stats for both members and staff, with CSV export and a deeper reporting screen for trend analysis over time.

| 8.3 Facilities

Administrators maintain the list of bookable facilities (courts, pool, studios, etc.), each with an occupancy limit, along with booking-volume stats per facility.

| 8.4 Bookings

A bookings dashboard covers today's, upcoming, guest, and cancelled bookings, and a form to create a new class, facility, or guest booking (guests do not need to be an existing member — name/email/phone are captured directly). Each booking carries its own confirmation status, payment status, and a QR code that can be used for check-in.

| 8.5 Training / Classes

A catalogue of classes and training sessions with trainer assignment and a fill-rate KPI, plus a "training streams" feature for live-streamed classes (start/end controls and engagement analytics — views, likes, participants).

9. SALES, POINT OF SALE & INVENTORY / PURCHASING

| 9.1 Point of Sale (POS)

The most feature-dense screen in the application. A cashier opens a till session (with a denomination count), sells products from a categorised catalogue, checks out with multiple payment methods, looks up a member to bill a purchase to their account, logs cash drops, processes sales returns, reprints receipts, checks prices, and views/updates a customer's running account statement (recording a payment or an advance). A simplified/kiosk POS variant is also available for lighter-weight checkout scenarios.

| 9.2 Product Catalogue & Inventory

Staff manage the product catalogue (add/edit, categorise, adjust stock, duplicate an item) and see stock-value and low-stock-alert KPIs, plus inventory analytics (top-value and low-stock reports). Products are tracked per warehouse, with stock adjustments recorded as discrete, auditable events rather than silent edits.

| 9.3 Purchasing & Suppliers

A purchase-order lifecycle (create, track approval status, mark as received against a supplier — potentially in stages) sits alongside a supplier bill/invoice workflow with its own approval process, plus a supplier directory. KPIs include overdue/urgent orders, monthly spend, and top suppliers.

| 9.4 Wastage & Returns

Stock write-offs (breakage, expiry, returns) go through a formal approval chain — submitted, then approved or rejected, then completed or cancelled — rather than being applied directly, as a control against unauthorised inventory loss.

| 9.5 Production & Recipes

For items made in-house (e.g. smoothies, supplements), recipes define ingredient quantities, and production orders consume those ingredients to create finished stock, with start/complete/cancel controls.

| 9.6 Sales & Purchasing Overview

A combined dashboard trends sales against purchases, shows gross profit, and surfaces recent sales and purchase orders, with dedicated reporting and analytics screens for the sales side specifically.

10. FINANCIALS & ACCOUNTING

GymBios implements genuine double-entry bookkeeping rather than a simplified income/expense tracker.

| 10.1 Chart of Accounts & Ledgers

Administrators maintain a chart of accounts ("account heads") and cost centers, each of which can be activated/deactivated, and can drill into a per-account ledger of every transaction posted to it.

| 10.2 Vouchers (Journal, Payment, Receipt)

Journal vouchers record multi-line debit/credit entries that must balance, and move through a draft → posted → cancelled/reversed lifecycle; reversing a voucher creates a new, linked reversing entry rather than editing history, preserving an audit trail. Payment vouchers record money going out (optionally against specific supplier bills); receipt vouchers record money coming in, with an income-source breakdown. A flag distinguishes vouchers a person created manually from ones the system generated automatically (e.g. from a POS sale).

| 10.3 Bank Reconciliation

Bank statement lines can be matched or unmatched against ledger entries, with a reconciliation moving through open → in-progress → completed states, including notes for unmatched items.

| 10.4 Expenses

Expenses are logged with categories and locations, moving through an approval-style status, with KPIs for tax paid and top spending categories.

| 10.5 Tax Compliance

A filing calendar tracks tax obligations (pending / filed / overdue / exempt) with due-this-week and overdue KPIs, tax-type configuration, and filing history.

| 10.6 Financial Reports & Analytics

Standard financial statements are generated on demand: income statement, balance sheet, trial balance, and cash-flow statement, plus an analytics dashboard covering monthly trends, revenue by source, and expense by category. Module-level settings cover tax rates and accepted payment methods.

11. HR & PAYROLL

| 11.1 Staff Directory

A directory of staff/trainers with profile details, assigned commission rules, certifications, and attendance/performance tracking. Like members, staff can optionally be granted a portal login with an access toggle.

| 11.2 Staff Attendance

Staff clock in and out (or are clocked in/out by an admin), with a live view of who is currently working and reports scoped to trainers specifically.

11.3 Payroll Processing

Monthly payroll calculates each employee's pay from salary, allowances, and attendance, generates payslips, and supports sending or downloading them. Payments can then be executed individually, in bulk, or reviewed via a payment summary and recent-transactions log.

11.4 Salary Advances

Employees can request salary advances/loans, which go through an approval step before disbursement, with a repayment schedule and a department-wise distribution report.

11.5 Targets & Commission

Admins can set sales/performance targets for staff and track aggregate achievement; commission rules (configurable, not hard-coded) tie into this to drive incentive pay.

11.6 Recruitment

A lightweight hiring pipeline tracks candidates and recruitment activity across overview, candidate-list, and activity-log views.

Note on Payroll Screens

Payroll-specific reports, analytics, and settings screens are linked from navigation but currently render only a placeholder — see §19.

12. ASSETS

Tracks the gym's physical equipment and fixed assets: a register of assets with CRUD management, a maintenance and transfer history feed per asset, a dashboard of recent activity/pending transactions/upcoming maintenance/high-value items, and reporting/analytics on asset utilisation.

Note on Asset Settings

The Asset Settings screen is linked from navigation but currently renders only a placeholder — see §19.

13. GYMOS & BIOS (ADMIN CONSOLE & AI INSIGHTS)

13.1 GymOS - Operations Control Panel

A systems-administration console covering integrations, security settings, notification configuration, connected-device/monitor status (with power controls), feature toggles, and permissions — effectively the operational "back office" for the platform as a whole. It also embeds the staff target-setting and targets-overview tools described in §11.5.

| 13.2 BIOS - AI-Driven Insights

An AI-assisted dashboard that pulls data from attendance, expenses, financial analytics, and membership to surface automatically generated recommendations and anomaly flags, with trend charts and drill-down filters, intended to help an owner/manager spot issues (e.g. a branch's attendance dropping, or spend spiking in a category) without manually cross-referencing multiple reports.

14. COMMUNITY & MEMBER SELF-SERVICE HUB

This is the member-facing side of the platform — screens designed for the gym member rather than staff, reached through the "Member Hub" area of the app.

| 14.1 Community Feed

A social feed where members can post updates, react, comment, and browse events, achievements, and a leaderboard, with activity KPIs (active members, posts today, challenges, RSVPs). Staff/admins can moderate content (archive or delete posts).

| 14.2 Member Hub & Profile

The member's home base aggregates the community feed with quick links to book a session, join a class, or view challenges. A consolidated self-service profile page covers personal info, performance, personal targets, transaction history, and account settings.

| 14.3 Personal Stats & Targets

Members can track their own fitness stats (attendance streaks/goals, weight and body-measurement history with progress photos, workout-type distribution, class history, challenge participation) and their own sales/fitness targets and achievements, mirroring the staff-facing targets tool but scoped to the individual.

| 14.4 Booking a Session or Class

Members can self-book personal-training/class sessions (with a summary and payment step) and browse/join scheduled group classes, including waitlisting when a class is full, with confirmation screens and an "own classes" view.

| 14.5 Challenges

Members can explore and join fitness challenges, track their own progress, view a leaderboard, and earn rewards/badges.

| 14.6 Emergency Profile

A special, login-free page (intended for QR/badge scanning) surfaces a specific member's emergency contact and medical information for use in a medical emergency — see §5.2.

15. AUTOMATION & NOTIFICATIONS

15.1 Automation Workflows

Administrators can create, enable/disable, and manually trigger automated workflows that watch for specific conditions and take an action (typically sending a message) when they occur. Each workflow can run once or on a recurring schedule (specific day of week/month, time of day, timezone-aware — default Asia/Kolkata), and includes a cooldown period so the same member isn't re-triggered repeatedly. A run log records total/successful/failed runs and how many members were reached; certain built-in ("system") workflows are protected from deletion.

15.2 Built-In Triggers

Trigger	Fires When...
Birthday	A member's birthday occurs
Class Reminder	A booked class is coming up
Low Attendance	A member's visit frequency drops
Membership Expiry	A membership is nearing / at its expiry date
Missed Workout	A member misses an expected session
New Signup	A new member or lead signs up

15.3 In-App Notifications

A notification bell/panel in the app shell shows unread counts and lets a user mark individual or all notifications as read, or dismiss them.

16. REPORTS & ANALYTICS

In addition to the module-specific reports described in earlier sections (financial statements, sales reports, asset reports, member-connect analytics, community analytics, attendance reports), the platform provides:

- **Dashboard** — a KPI command-centre (revenue, active members, check-ins, attendance) with trend charts, a live notifications feed, and quick-action shortcuts into other modules.
- **Reports & Analytics hub** — overview, membership, revenue, and operations tabs covering growth trend, revenue distribution, peak-usage hours, acquisition vs. churn, and demographics.
- **Custom Report Builder** — an ad hoc reporting tool alongside a pre-built detailed membership report, also reachable from the member directory.

17. DATA MODEL OVERVIEW

The system's data is organised around roughly 77 entities. The table below groups the most functionally significant ones by module for quick reference; it is not an exhaustive schema.

Module	Key Entities
Membership	Member, MembershipPlan, MemberAddon
CRM	Lead, LeadInteraction, FollowUp, CommunicationRecord, Referral, ReferralRewardRule, PromotionCampaign
Attendance / Bookings	Attendance, DeviceKey, Facility, FacilityRate, Booking, TrainingSession, TrainingStream
Sales / POS	PosSession, SaleTransaction, SaleTransactionItem, Receipt
Inventory / Purchasing	Product, ProductCategory, ProductStock, ProductUnit, Warehouse, StockAdjustment, Supplier, SupplierBill, SupplierBillItem, PurchaseOrder, PurchaseOrderItem, WastageReturn, WastageReturnItem, Recipe, RecipeIngredient, ProductionOrder
Financials	AccountHead, CostCenter, JournalVoucher, JournalVoucherLine, JournalEntrySource, PaymentVoucher, PaymentVoucherBill, ReceiptVoucher, CashMovement, BankReconciliation, BankStatementLine, Expense, FinancialSetting, TaxCompliance
HR / Payroll	Staff, StaffAttendance, StaffCertification, StaffScheduleSlot, StaffTarget, CommissionRule, SalaryAdvance, SalaryPayment, SalaryPaymentEmployee
Assets	Asset, AssetMaintenance, AssetTransfer
Community	CommunityPost, CommunityPostComment, CommunityPostLike
Automation / Messaging	AutomationWorkflow, AutomationExecutionLog, Notification, MessageCampaign, MessageGroup, MessageRecipient, MessageTemplate
Identity	User, Role, UserRole

17.1 Notable Member Fields

Business ID (e.g. MBR-xxxx), membership type/status/plan, join/start/end/expiry dates, payment status, outstanding balance, freeze period and reason, family-plan linkage (family head / dependent relationship), medical/health information, a face-recognition identifier for check-in, and optional portal-login credentials.

17.2 Notable Financial Fields

Journal vouchers carry a voucher number, narration, total debit/credit, status, and a flag for whether they were system-generated; each line carries an account, debit/credit amount, and cost center. Reversed vouchers are linked to the voucher that reversed them and vice versa, preserving a full audit trail instead of overwriting history.

18. NON-FUNCTIONAL REQUIREMENTS

Category	Current Implementation
Authentication	JWT-based, 24-hour token expiry, BCrypt password hashing
Authorisation	Role model defined (7 roles) but not currently enforced at the API layer — see §19
Auditability	Strong in Financials (append-only voucher reversal, execution logs for automations); weaker elsewhere, where status fields are simple mutable strings
Data integrity	Enforced mainly at the application/service layer; most status/state fields are free-text rather than database-enforced enumerations
Localisation	Timezone-aware scheduling in Automations (default Asia/Kolkata); no evidence of multi-language UI support
Extensibility	Automation triggers use a pluggable handler pattern, making it straightforward to add new trigger types
Multi-tenancy	No evidence of multi-branch / multi-tenant data partitioning in the reviewed code — appears to model a single gym / organisation
Deployment target	Standard Spring Boot + PostgreSQL backend with a static-hosted SPA frontend; a companion Expo mobile app exists in-repo

19. KNOWN GAPS, RISKS & INCOMPLETE AREAS

These items were identified directly from the code during preparation of this document and are flagged so they are tracked deliberately rather than discovered by accident.

19.1 API authorisation is effectively open

The backend's security configuration defines sensible role restrictions per API area (e.g. payroll limited to HR/ADMIN, billing limited to ACCOUNTANT/MANAGER/ADMIN), but a catch-all rule that permits all requests to `/api/**` is evaluated first, so in practice almost every endpoint accepts unauthenticated or any-role requests. Only the Community module enforces "must be logged in" at the method level. **Recommendation:** before any production/public deployment, remove or scope down the permissive catch-all rule and verify each role-restricted area actually rejects out-of-role requests.

19.2 Frontend role checks are inconsistent, not centralised

The application does not restrict which pages a logged-in user can navigate to based on their role — every user sees the same navigation and can browse to any route, including financials, payroll, and admin screens. Individual pages perform their own local checks (reading the role out of session storage) to decide whether to show admin-only buttons (e.g. deleting a community post). This means role-based UI behaviour is easy to miss or get inconsistent when new pages are added. **Recommendation:** introduce a shared route-level guard driven by role, rather than relying on each page to opt in individually.

19.3 Placeholder screens

The following screens are linked from the navigation menu but currently show only a "coming soon"-style placeholder with no real functionality behind them: Sales Settings, Payroll Reports, Payroll Analytics, Payroll Settings, Asset Settings, and Profile Settings.

19.4 Orphaned / unrouted pages

A handful of page components exist in the codebase but are not currently reachable from any route in the application: `addon-membership.tsx`, `clients.tsx`, `renew-upgrade.tsx`, and `scheduling.tsx`. A second community-feed implementation (`community.tsx`) also exists alongside the currently-routed one (`community-redesign.tsx`) and is only used internally as a "create post" dialog. These should be confirmed with the development team as either superseded work-in-progress or features awaiting wiring up, before being represented as live functionality to stakeholders.

19.5 No visible self-service password recovery or sign-up in the live app

The backend supports user registration, but the routed frontend does not currently expose a sign-up or "forgot password" flow — new accounts appear to be provisioned by staff via the Members/Staff "set credentials" actions instead.

19.6 Free-text status fields

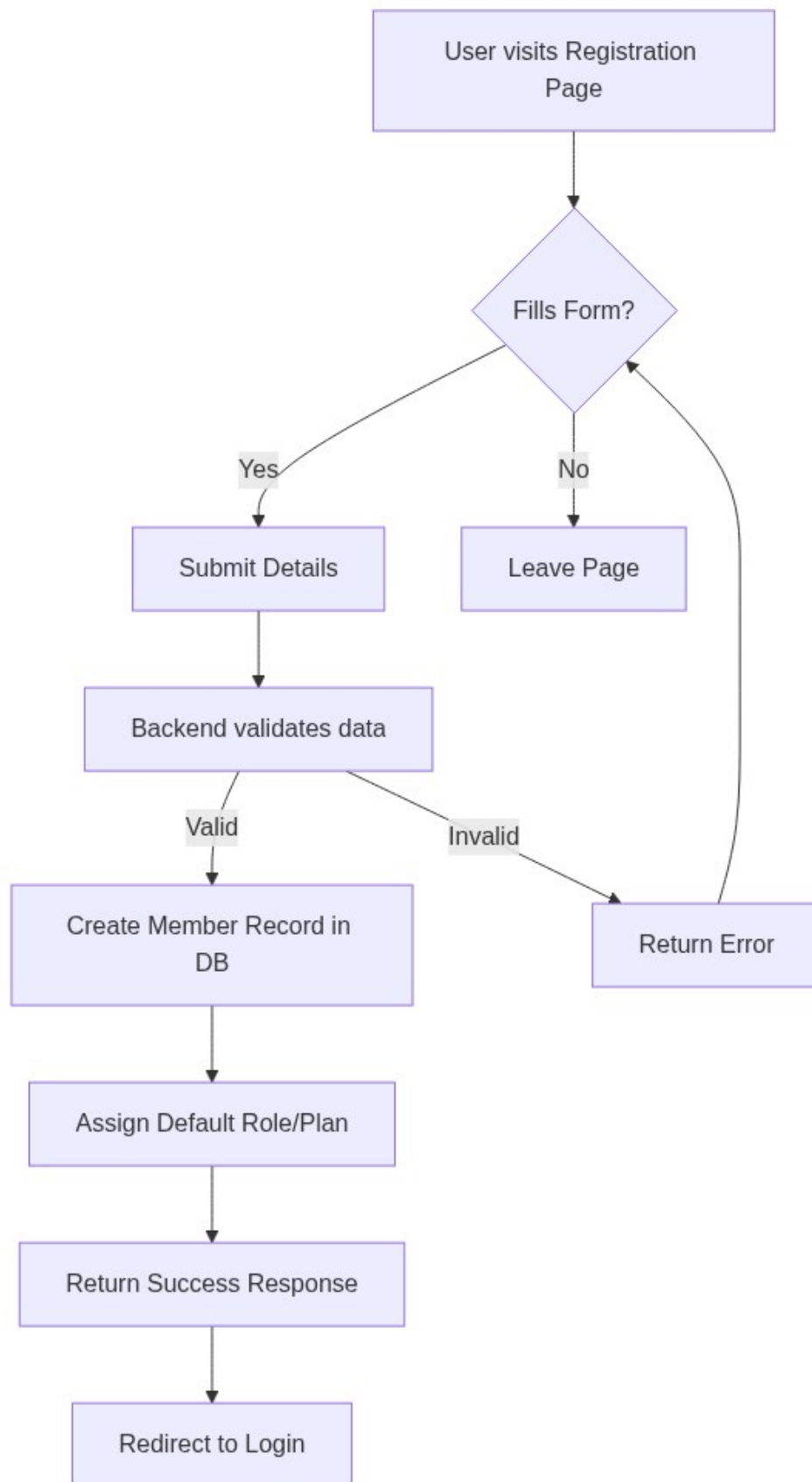
Because most workflow states (membership status, approval status, voucher status, etc.) are stored as plain strings rather than a constrained set of values, the "valid" set of states for any given field is a convention maintained in application code, not something the database or compiler will catch if violated. This is a design choice worth being aware of when extending any status-driven workflow.

20. GLOSSARY

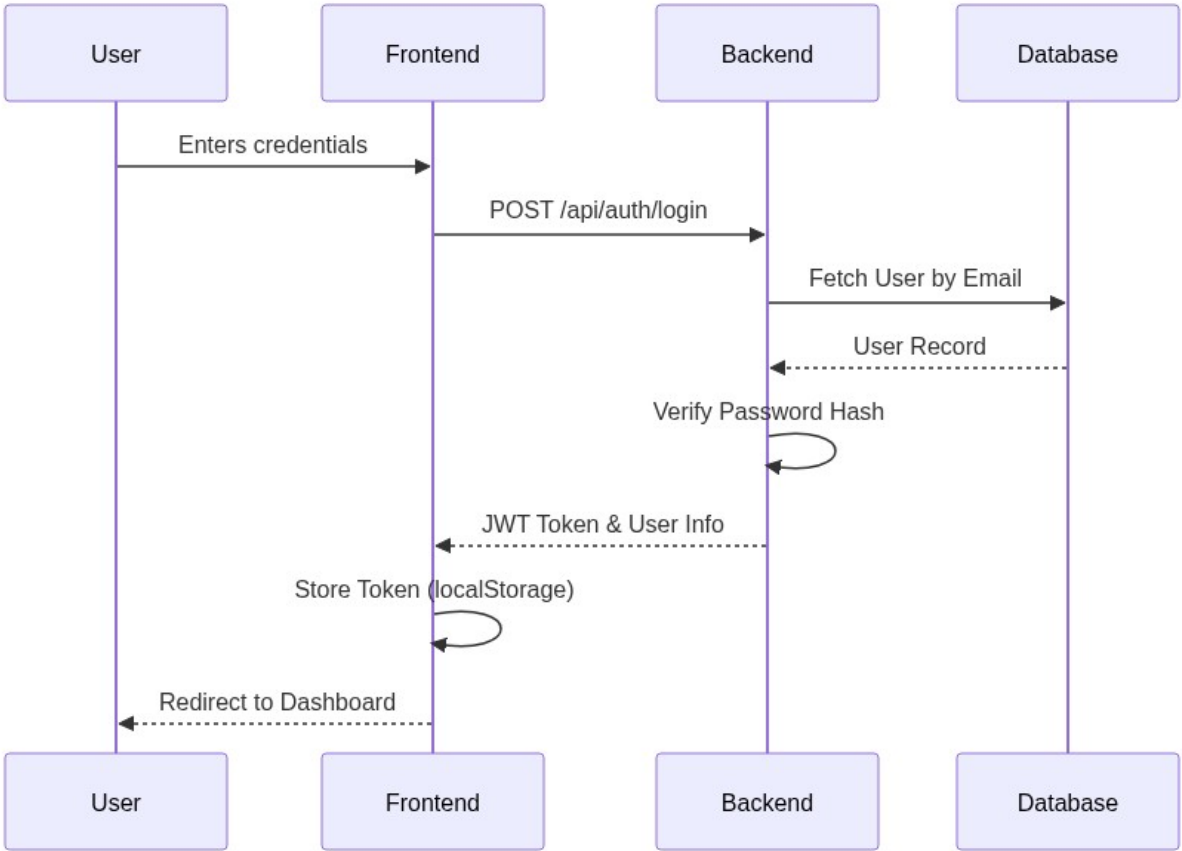
Term	Meaning
FSD	Functional Specification Document — this document
JWT	JSON Web Token — the signed token used to identify a logged-in user
POS	Point of Sale — the retail checkout module
Voucher	An accounting document recording a financial transaction (journal, payment, or receipt)
Double-entry bookkeeping	An accounting method where every transaction is recorded as a balanced debit and credit
GymOS	The platform's internal admin / operations control panel
BIOS	The platform's AI-driven business-insights dashboard
Member Hub	The member-facing self-service area of the application
Cooldown (automation)	A minimum waiting period before the same automation can trigger again for the same member
Device key	A credential issued to a physical check-in device (not a person) so it can authenticate to the API

This document was generated by reviewing the Gym-backend and Gym-frontend source trees on 21 July 2026. It describes the system as implemented at that point in time and should be refreshed as the codebase evolves.

Member Onboarding Flow



Authentication Flow



Subscription Renewal Flow

